WEEK 6 REPORT

OWASP • Web Security & Vulnerability Testing (VAPT Basics)

Internship Activity	Cybersecurity Internship – DG Interns Hub
Tools / Lab	XAMPP, DVWA, Burp Suite Community Edition
Scope	Local, intentionally vulnerable DVWA environment

Purpose: document the concepts studied, local lab setup, observed test results, limitations, and recommended mitigations. This report distinguishes completed activities from work that could not be completed.

Prepared as a learning report. All testing described here is limited to the local DVWA lab and authorized environments.

1. Executive Summary

This Week 6 activity introduced common web application vulnerabilities and basic vulnerability assessment and penetration testing (VAPT) practices. XAMPP was used to host DVWA locally. The lab was opened with its security level set to **Low**, and the screenshots show successful demonstrations of SQL injection and reflected/stored cross-site scripting (XSS) behaviour.

Burp Suite Community Edition was opened and its HTTP history was inspected. The supplied screenshot shows connectivity-check traffic, not a captured DVWA request, so a DVWA-specific Burp capture is not claimed as completed. An OWASP ZAP automated scan and exportable scan report were also not completed: the file intended for that part of the activity was reported as malicious/unsafe, so it was not opened or executed. This was treated as a safety stop rather than bypassed.

Key outcomes

- Installed/used the local XAMPP environment and located the DVWA folder under htdocs.
- Confirmed the DVWA security page reported the security level as Low.
- Observed SQL injection returning multiple records when the input condition was manipulated.
- Observed browser alert dialogs labelled “XSS” and “Stored XSS” in the lab.
- Identified evidence gaps and recorded safe next steps instead of claiming tests that were not completed.

Report contents

2. Objectives • 3. VAPT & OWASP overview • 4. Tools and environment • 5. Lab setup • 6. SQL injection test • 7. XSS tests • 8. Burp Suite review • 9. OWASP ZAP limitation • 10. Findings and risk • 11. Mitigation • 12. Conclusion and references.

2. Objectives and Scope

Objectives

• Understand the purpose of OWASP guidance and common web application risks.

• Set up a deliberately vulnerable application locally using XAMPP and DVWA.

• Demonstrate basic SQL injection and XSS behaviours in a controlled training lab.

• Become familiar with inspecting HTTP traffic using Burp Suite Community Edition.

• Understand the role of OWASP ZAP in automated scanning and document why that task was not completed.

Scope and authorization

Testing was performed against the local DVWA application at localhost. DVWA is intentionally vulnerable and designed for training. These demonstrations must not be repeated against public websites or systems without explicit permission. No production system, third-party account, or real user data was in scope.

Method

The workflow was: prepare the local lab; verify that the application loads; select a deliberately low DVWA security setting for the demonstration; submit test input in the relevant DVWA pages; observe the application response; capture screenshots; and map each observation to a risk and mitigation. Testing was limited to the actions evidenced by the supplied screenshots.

Evidence standard

Screenshots in this report are evidence of the visible interface/output only. They do not prove a complete security audit. No ZAP findings, exported scan file, or DVWA-specific Burp request/response are included because those artefacts were not provided.

3. Introduction to VAPT and OWASP

Vulnerability Assessment and Penetration Testing (VAPT)

A vulnerability assessment identifies and prioritizes weaknesses in an application or environment. Penetration testing safely validates whether selected weaknesses can be exploited and what impact they may have. A responsible VAPT process defines authorization and scope, uses controlled tests, records evidence, rates risk, recommends fixes, and retests after remediation.

OWASP

The Open Worldwide Application Security Project (OWASP) is a community-led organization that publishes resources for improving application security. The OWASP Top 10 is an awareness document highlighting important categories of web application risk. It is not a substitute for a complete security standard or a penetration test.

Relevant risk categories

- **Injection:** untrusted input changes the meaning of a database query or command.
- **Identification and authentication failures:** weaknesses in login, session management, or identity verification.
- **Security misconfiguration:** unsafe defaults, unnecessary services, verbose errors, or insecure settings.
- **Cross-site scripting (XSS):** untrusted content is interpreted as executable script in a user's browser.
- **Broken access control:** users can access data or functions beyond their authorization.

This report focuses on SQL injection and XSS because those behaviours are directly visible in the supplied DVWA screenshots. Other categories are summarized for awareness and were not tested in this session.

4. Tools and Lab Environment

Tools used

• **XAMPP:** local development stack providing Apache and MariaDB/MySQL services for the lab.

• **DVWA:** Damn Vulnerable Web Application, a deliberately insecure application intended for security training.

• **Burp Suite Community Edition:** web security testing proxy with HTTP history and request/response inspection features.

• **OWASP ZAP:** intended for a later automated scan; scan execution and export were not completed.

Setup observations

The browser screenshot shows the XAMPP dashboard loading at localhost. The control-panel screenshot shows Apache running on ports 80/443. MySQL initially logged an unexpected shutdown and later showed a running status; the lab was subsequently accessible. File Explorer shows the DVWA-master folder inside C:\xampp\htdocs. DVWA's security page shows the security level set to Low.

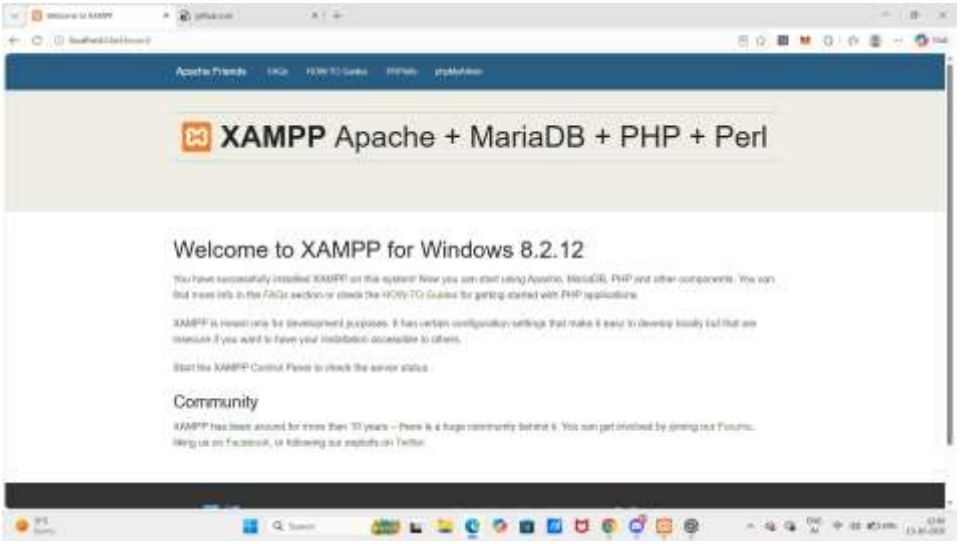


Figure 1. XAMPP dashboard confirms the local web stack is reachable.

5. Setup Evidence and Safety

The local environment was prepared for controlled demonstrations. The screenshots below document the XAMPP control panel, the DVWA directory location, and the DVWA security setting.

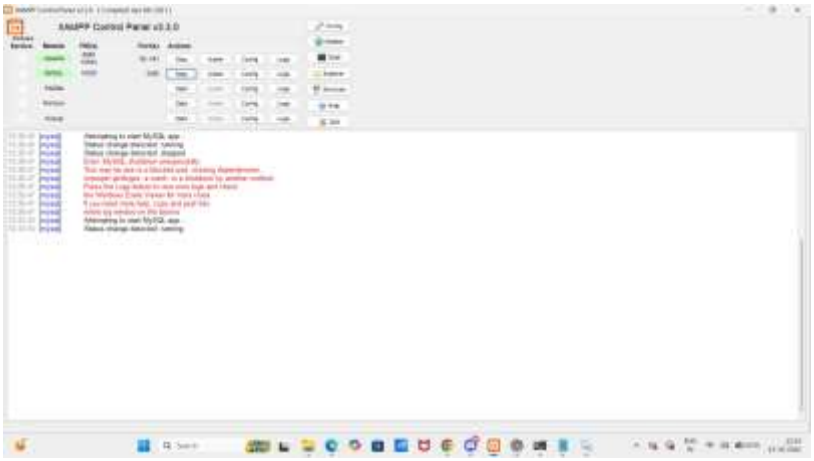


Figure 2. XAMPP control panel: Apache is running; the log records an earlier MySQL shutdown followed by a later running status.

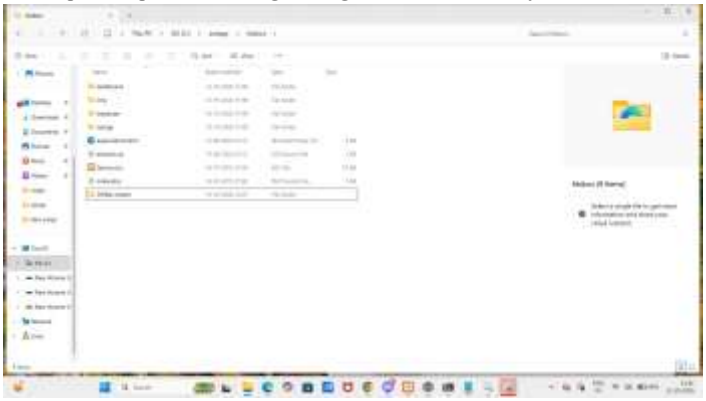


Figure 3. DVWA-master folder located under the XAMPP htdocs directory.

6. Test 1 — SQL Injection

Concept

SQL injection occurs when an application combines untrusted input with a database query without safely separating data from SQL instructions. Depending on the query and database permissions, an attacker may be able to view or alter records or bypass intended checks.

Lab observation

On DVWA's SQL Injection page, submitting a normal user ID of 1 returned the record for admin. A subsequent controlled lab input containing a tautology caused multiple records to be displayed, including several names. This indicates that the input affected the query logic in the deliberately vulnerable application.



Figure 4. Baseline SQL injection page response for user ID 1.



Figure 5. The manipulated input returned multiple records in the DVWA lab.

Result: demonstrated in the local training application. This is not evidence of a vulnerability in any external website.

7. Test 2 — Cross-Site Scripting (XSS)

Reflected XSS

Reflected XSS occurs when input from a request is immediately included in a response in an unsafe way. If the browser interprets the input as script, it may execute in the page's security context. The screenshot shows a browser alert labelled “XSS” after the reflected XSS page was loaded with test input.

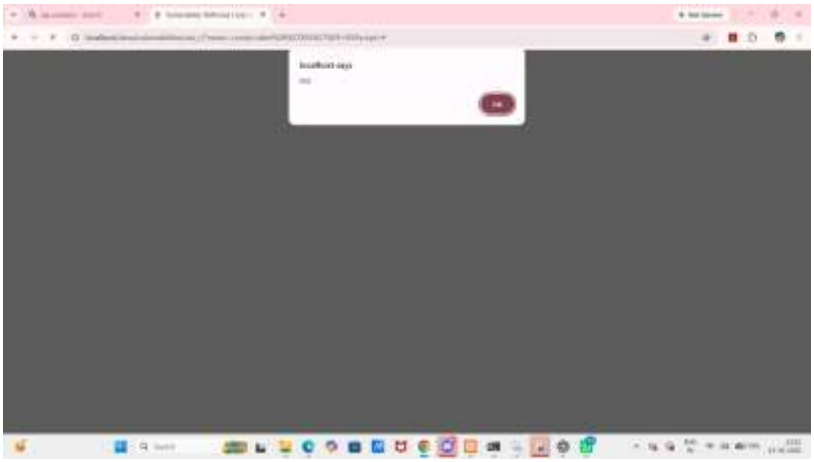


Figure 6. Reflected XSS demonstration: browser alert shown by the local DVWA lab.

Stored XSS

Stored XSS occurs when untrusted content is saved by an application and later displayed to users without appropriate output encoding or sanitization. The screenshot shows an alert labelled “Stored XSS” on the DVWA stored XSS page.



Figure 7. Stored XSS demonstration: browser alert shown by the local DVWA lab.

8. Burp Suite Community Edition Review

Burp Suite can act as an intercepting proxy between a browser and a web application. Its HTTP history records requests and responses that pass through the configured proxy, allowing a tester to inspect methods, paths, parameters, headers, cookies, status codes, and response content.

Evidence review

The supplied Burp screenshot shows HTTP history entries for operating-system connectivity-check requests (for example, a connectivity-check host and a 204 response). It does not show a request to localhost/DVWA. Therefore, Burp was opened and HTTP history was viewed, but a DVWA-specific request/response capture is not evidenced and is not reported as completed.

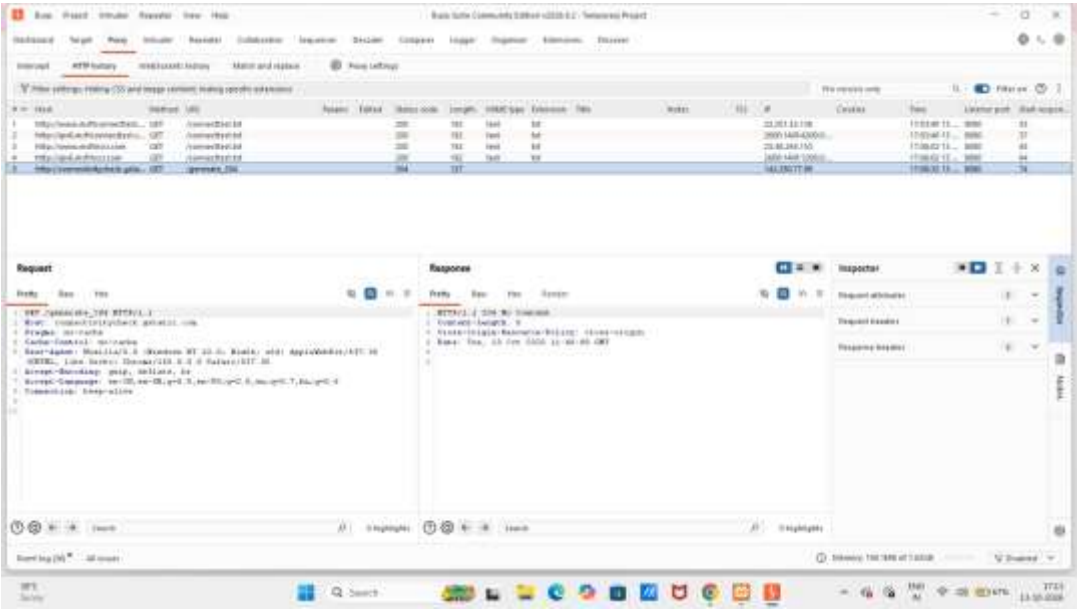


Figure 8. Burp Suite HTTP history screenshot. Visible traffic is connectivity-check traffic, not a DVWA request.

Recommended next step

For a future authorized lab session, configure the browser to use Burp's local proxy, visit the local DVWA page, and verify that a localhost request appears in HTTP history before documenting it. Avoid capturing unrelated private traffic.

9. OWASP ZAP Scan — Limitation and Safe Handling

Planned activity

The Week 6 task called for running an OWASP ZAP automated scan against DVWA or an approved test target, reviewing identified alerts, and exporting a scan report. This step was not completed.

Reason

The file intended for this part of the activity was reported by the user as malicious/unsafe, so it could not be used. It was not opened or executed, and no attempt was made to bypass the warning. The screenshots supplied do not include a ZAP scan result or exported report.

Conclusion and Learning Outcomes

The Week 6 exercise provided practical exposure to web application security using a local, intentionally vulnerable DVWA instance. The screenshots document XAMPP/DVWA setup, a SQL injection demonstration, and reflected and stored XSS alerts. These results reinforce why applications must treat user input as untrusted and encode output safely.

Some requested activities remain incomplete. The available Burp screenshot contains connectivity-check traffic rather than DVWA traffic, and an OWASP ZAP scan/export was not performed because the file needed for that task was reported as malicious/unsafe. The file was not opened or executed. Reporting these limitations accurately is part of responsible security practice.

Checklist

- XAMPP and local DVWA access — evidenced.
- SQL injection demonstration — evidenced in DVWA.
- Reflected and stored XSS demonstrations — evidenced in DVWA.
- Burp Suite opened / HTTP history reviewed — evidenced; DVWA-specific capture not evidenced.
- OWASP ZAP scan and export — not completed.
- Findings and mitigations — documented at an educational level.

References

- OWASP Top 10: https://owasp.org/www-project-top-ten/
- OWASP SQL Injection Prevention Cheat Sheet:https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html
- OWASP Cross Site Scripting Prevention Cheat Sheet:https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html
- Damn Vulnerable Web Application (DVWA): https://github.com/digininja/DVWA
- Burp Suite documentation: https://portswigger.net/burp/documentation
- OWASP ZAP documentation: https://www.zaproxy.org/docs/

Disclaimer: This is a learning report based on the supplied screenshots and the user's description of the incomplete ZAP task. It is not a comprehensive audit or a claim that all Week 6 tasks were completed.